

Security Concepts

Computer Systems Security

2025/26

LEI - UM

Hugo Pacheco hpacheco@di.uminho.pt

“Security”?

- There is no universal definition
- Definition #1:
 - **“The system behaves as expected”**
 - Says nothing about what the system **shall** / **shan't do**

Security



- Definition #2:
 - ***“System that remains dependable in the face of malice”*** (Ross Anderson)
- Correctness $\subset$ Security
 - Correctness: good input $\Rightarrow$ good output
 - Security: bad input $\nRightarrow$ bad output
- Informal, but bad behaviour is large and hard to quantify

Security



- Definition #3:
 - ***“Computer security, cybersecurity or information technology security (IT security) is the protection of computer systems and networks from information disclosure, theft of or damage to their hardware, software, or electronic data, as well as from the disruption or misdirection of the services they provide.”*** (Wikipedia)
- More holistic vision
- Comprehensive listing of categories of attacks?

Security



- Definition #4:
 - ***“Software security is about integrating security practices into the way you build software, not integrating security features into your code”***
(Gary McGraw)
- Security engineering
- Typical of software engineering
- Mitigation / resilience against more likely threats

Security

A classical meme

- Absurd?
 - “Secure” when the goal is to forbid a car in the road to override the barrier...
 - ...but not ignore the barrier
 - It all comes down to assumptions!



Security

A new perspective

- Security **is relative**
 - Does not mean anything by itself
 - Always depends on who defines it and how
- Security **changes with context**
 - Everything, including the definition/terminology, depends on the concrete application
- Security **is defensive**
 - Must be defined in the negative
 - Much harder than ensuring that a concrete behaviour happens

Security

Actors

- Actors are entities that intervene in the system
 - People, organisations, companies, machines, ...
 - **Security is defined from the perspective of these actors**
- We often deposit **trust** in some actors or system components
 - e.g., Trusted Third Party (TTP), Trusted Agent (TA), Trusted Setup
- We often consider some actors as potential (internal/external) **attackers**

Security

Adversaries / Attackers

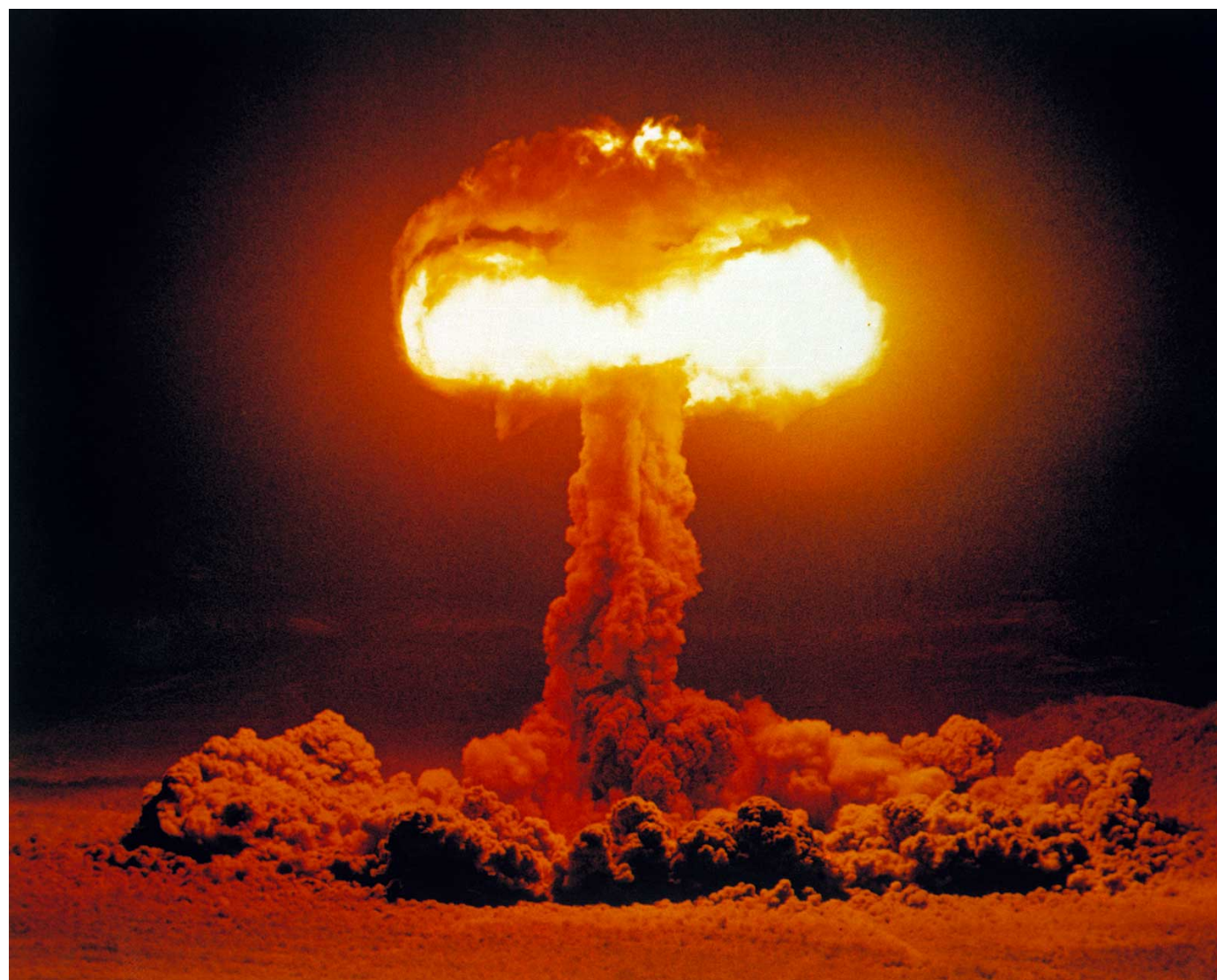
- In computer security we analyse the behaviour of systems when they interact with **adversaries**
- Actors with explicit intention of using the system/resources in a wrong way and/or to inhibit its usage



Security

Adversaries / Attackers

- No system is secure against all attackers



Security

Adversaries / Attackers

- It is essential to know our adversary (motivation, capabilities, access):
 - “Script-kiddies” (curious but ineffective)
 - Occasional attackers that seek to understand the system
 - Malicious attackers with intention to cause harm
 - Organised and technically sophisticated groups (e.g., cybercrime)
 - Business competitors (industrial espionage)
 - Countries/States/Governments



Security

Always a compromise

Hackers Are Targeting Your Smart Home. Here's How to Stop Them

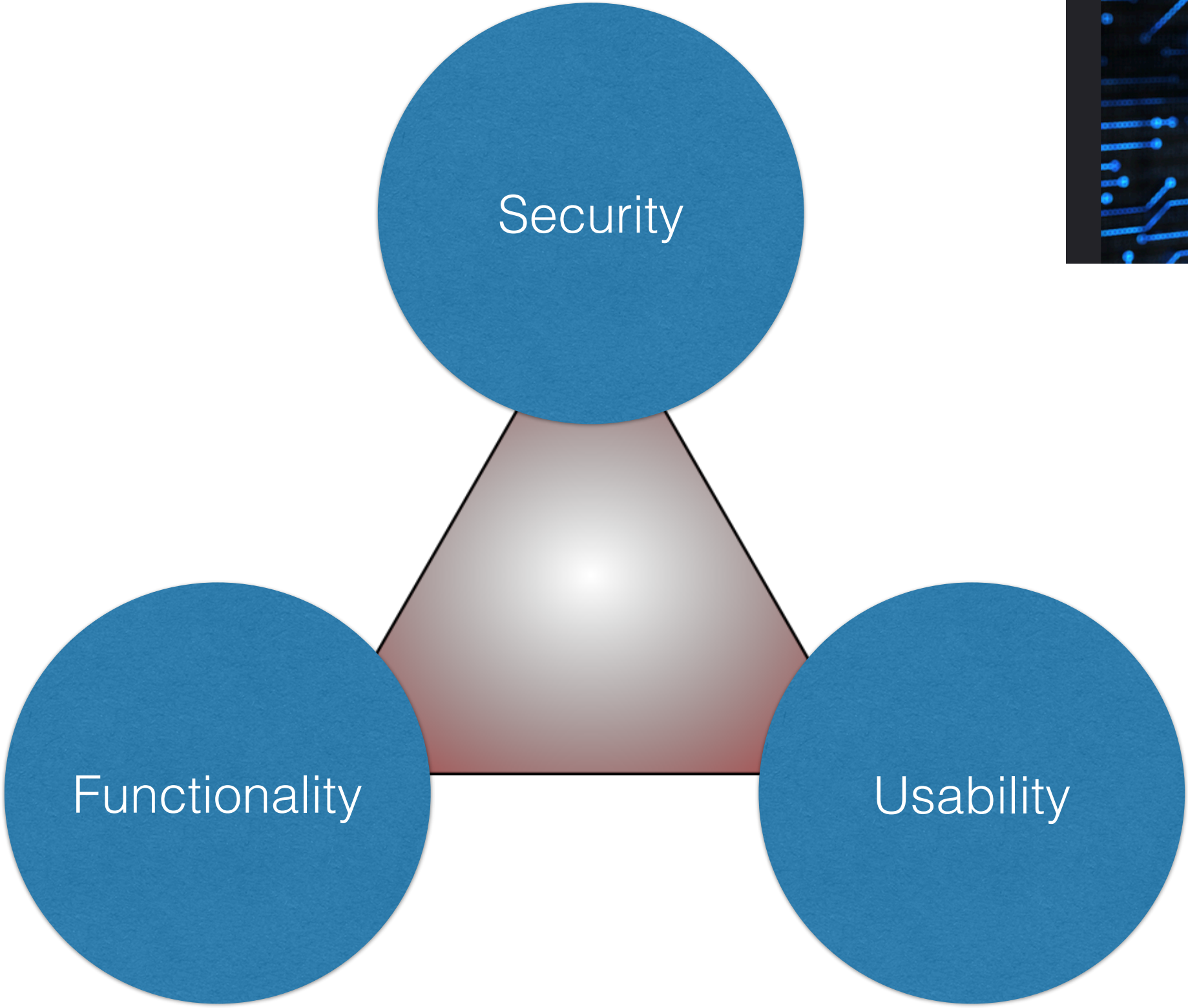
Smart homes offer convenience with a side of security risks. Here's how to prevent hackers from gaining access to your smart speaker, thermostat, doorbell, and other connected devices.

OUR EXPERT



Jason Cohen
Senior Editor, Help & How To

As how-to editor, Jason unpacks modern technology to help you make sense of it and put it to work in your daily life.



 YOUR PASSWORD HAS EXPIRED

NIST proposes barring some of the most nonsensical password rules

Proposed guidelines aim to inject badly needed common sense into password hygiene.

DAN GOODIN – 25 SEPT 2024 23:39 | 352



Security

Security by design

- Rigorous definitions
 - Formally define the capabilities of **attackers X** and the **security goals Y**
- Security proofs
 - No **attacker** limited to **X** can break **security goal Y**
- Typical of cryptography and dependable systems

Information Security

A known triad

- **Confidentiality:** Preserving authorised restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information. A loss of confidentiality is the **unauthorised disclosure** of information.
- **Integrity:** Guarding against improper information modification or destruction, including ensuring information nonrepudiation and authenticity. A loss of integrity is the **unauthorised modification** or destruction of information.
- **Availability:** Ensuring timely and reliable access to and use of information. A loss of availability is the **disruption of access** to or use of information of an information system.



Cryptography

- *“Cryptography is an important computer security tool that deals with techniques to store and transmit information in ways that prevent unauthorized access or interference” (ISO)*
- Cryptography is a **security mechanism**, used in combination with others to achieve the goals of information security
- Defence against common threats, such as:
 - unauthorised access, data breaches
 - tampering, eavesdropping

Cryptography

Origins

- “Kryptós” (hidden) + “Gráphein” (writing)
 - art of transmitting “secrets” (in an open channel)
 - Used since ancient times, often associated with military and diplomatic activities
- Historical focus on *ciphers*, whose goal is to enforce
 - **Confidentiality**: secrecy of messages



Cryptography

History

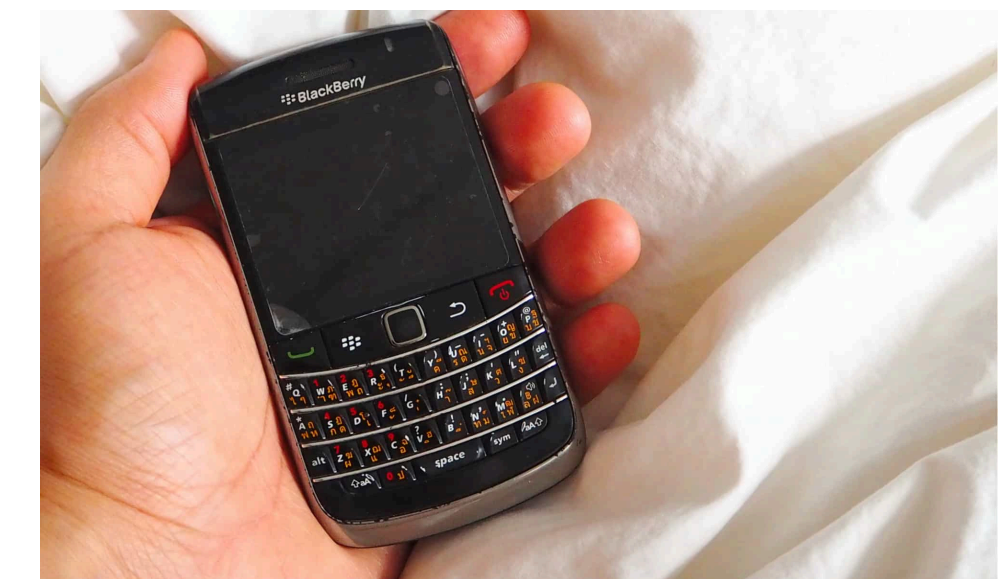
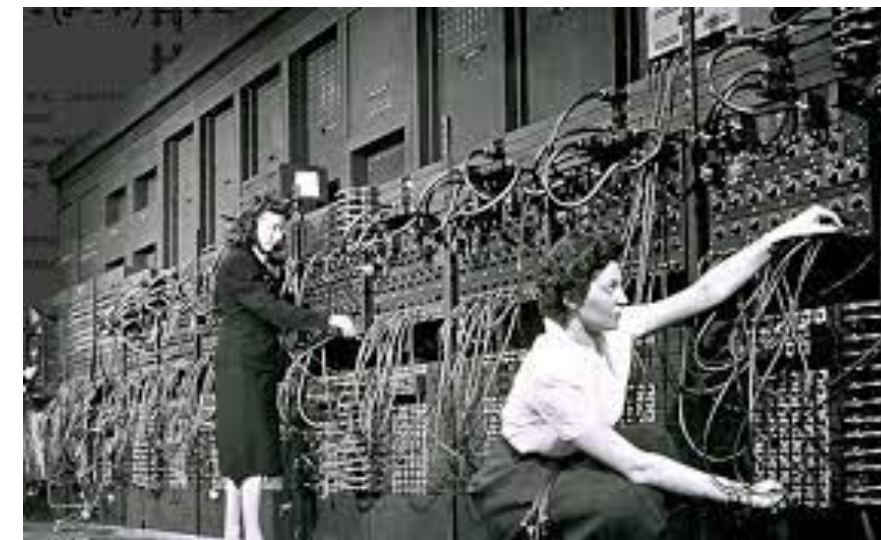
- The use of (proto) ciphers has been known since the 15th century BC
- Armies of classical empires (e.g. Romans) regularly used cryptography
- The sophistication of the techniques has evolved over the centuries
- E.g. Enigma machine (World War II, Germany)
- Shortly after World War II, Claude Shannon ([video](#)) published two seminal papers on Information Theory, which allowed for the formalisation of cipher security
 - Considered **the birth of Cryptography as a scientific field**



Cryptography

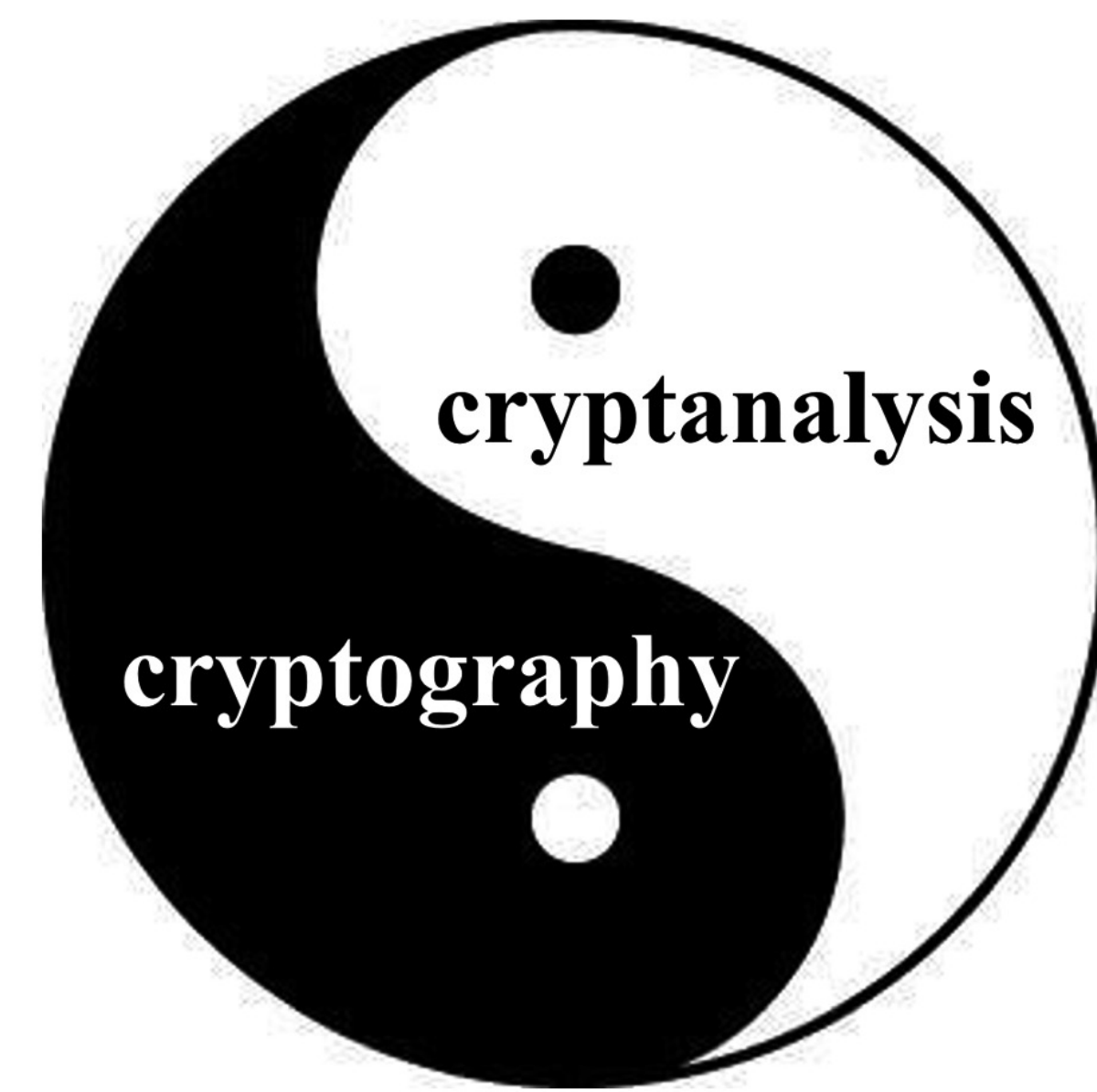
Modern History

- 1948/49 – Information Theory (Claude Shannon)
- 1970/77 – Data Encryption Standard (DES)
- 1976 – Public-key Cryptography (Diffie & Hellmann)
- 2001 – Replacing DES: Advanced Encryption Standard (AES)
- 2022/... – Post-Quantum Cryptography
- ...



Cryptology

A dual view



- In contrast, **cryptanalysis** aims to undermine the goals of cryptography
- A **cryptographic** technique is deemed **broken** if its objectives have been successfully compromised through **cryptanalysis**
- **Cryptography** and **Cryptanalysis** form an area sometimes called **Cryptology**
- As a scientific discipline, cryptology touches on several different fields, such as probability, complexity theory, information theory, computer science, etc

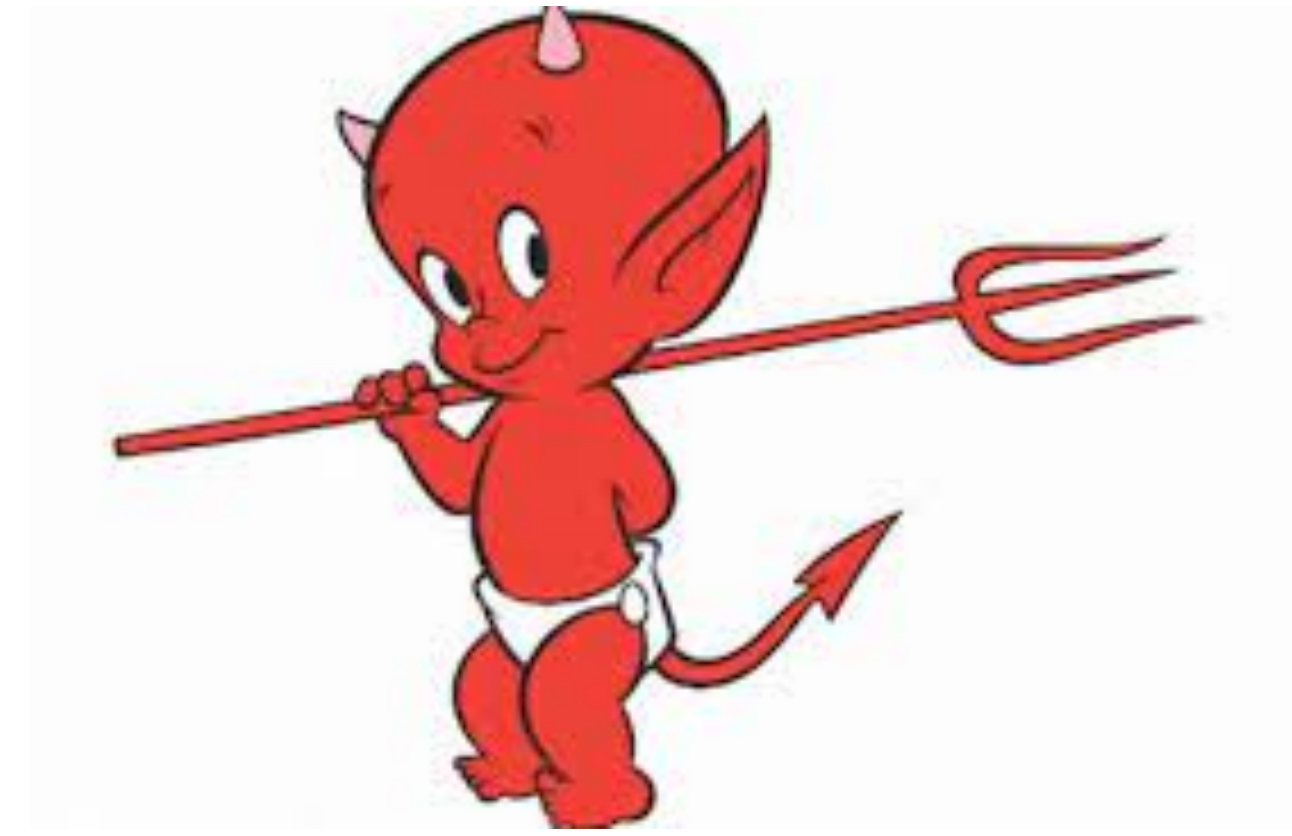
Cryptography

Security properties

- Today, cryptography is used to provide a wide range of guarantees related to information security under hostile environments
 - **Confidentiality:** message content is only known to the legitimate parties
 - **Integrity:** the recipient would “reject” messages that have been tampered
 - **Authenticity:** ensures the “origin” of the message to the recipient
 - **Non-repudiation:** the “origin” of the message cannot deny it
 - **Anonymity:** no information available regarding the “origin” of the message
 - **Identification:** establish the “identity” of a party
 - ...

Cryptography

Adversaries / Attackers



- Personalisation of the **hostile environment**
- Also known by the name of **enemy, spy, (E)ve, (M)allory, ...**

Adversary success $\Rightarrow$ The cryptographic technique is **broken**

- **Cryptographic security** can be defined as the absence of attacks

No adversary success $\Rightarrow$ The cryptographic technique is **secure**

Cryptography

Adversaries / Attackers

- It is essential to describe the adversary's capabilities
 - Attack type / degree of control
 - **Passive:** the adversary can only eavesdrop on the communication channel
 - **Active:** the adversary has the ability to manipulate information circulating on the communication channel (modify / block / insert or repeat messages)
 - Computational power
 - **Unbounded:** the adversary is able to execute any algorithm instantaneously; is assumed to have infinite time and infinite computing power
 - **Bounded:** adversary can only execute algorithms in some complexity class (e.g. Probabilistic Polynomial Time (PPT))
 - Additional information (e.g. transcripts of previous communications)
 - ...

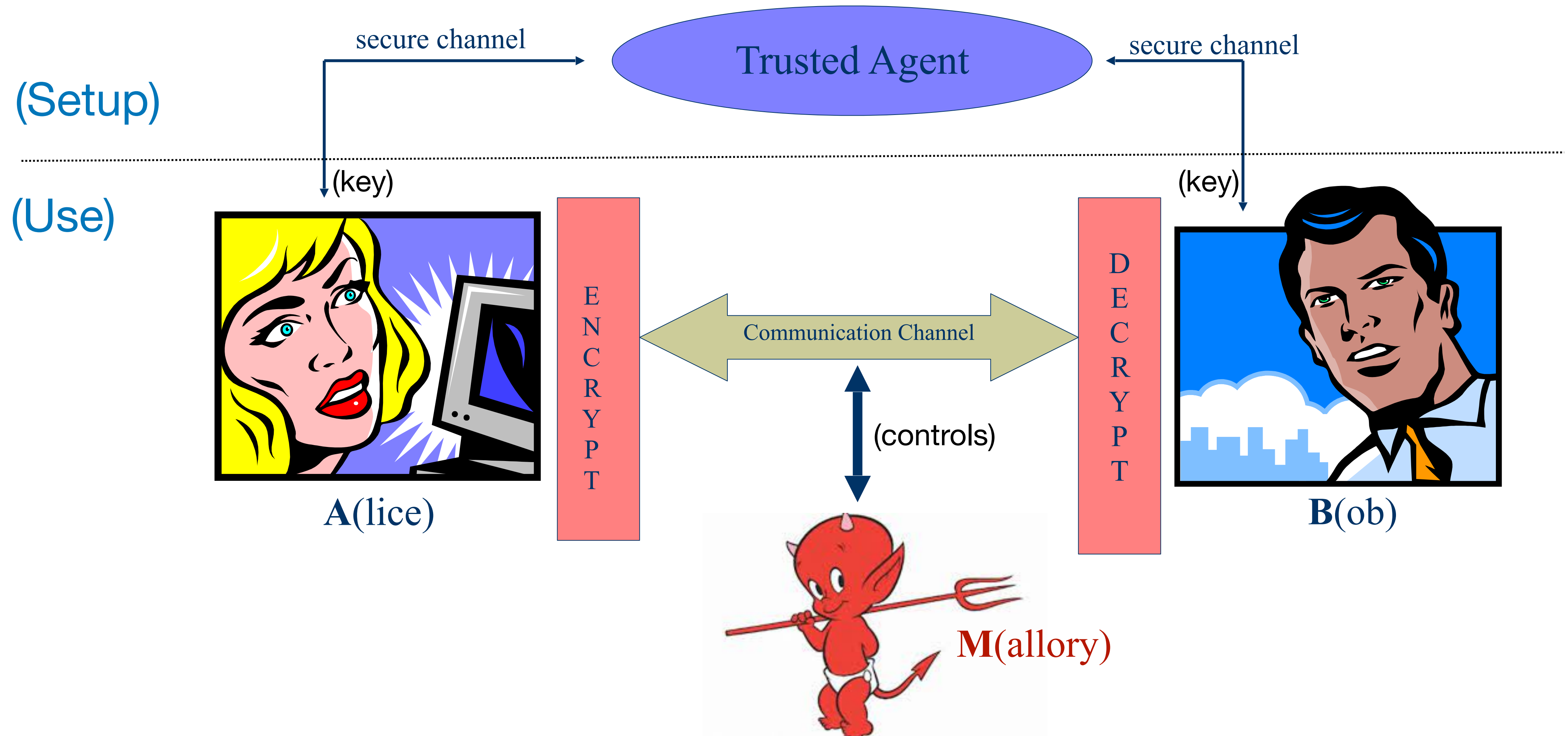
Cryptography

Adversaries / Attackers

- Depending on the type of adversary being considered
- Different notions of (cryptographic) security can be achieved
 - **Unconditional (or information-theoretic) security:** secure against a computationally unbounded adversary
 - **Statistical security:** secure against an adversary that may win by a (typically negligible) error margin
 - **Computational security:** secure against a computationally bounded — more precisely Probabilistic Polynomial Time (PPT) — adversary

Cryptography

Security model (confidentiality example)



Cryptography

Some terminology

- **plaintext** (or **cleartext**): content of the message
- **encryption**: operation that encodes the plaintext into an obscured message (**cyphertext** or **cryptogram**)
- **decryption**: inverse operation of encryption
- **cryptographic system**: specification of the (possibly probabilistic) algorithms that perform some cryptographic technique (e.g. key-generation, encryption, decryption)
- **trusted agent**: benign environment
- **attack**: compromise of the security goals (e.g. discover the transmitted message without the corresponding key)
- **adversary**: hostile environment

Cryptography

Security assumptions

- Historically, security was largely attributed to the secrecy associated with the underlying technique
 - Also known as **security through obscurity**
 - “the less people know, the harder it is to attack”
 - Which had disastrous consequences!
- Not so long ago!
 - Trend was still present in the 20th century
 - And in some places today...



Cryptography

Security assumptions



- As early as the 19th century, *Auguste Kerckhoff* established a principle
the security of a cipher must be assessed on the assumption that all the details of its construction are public knowledge
- Revolutionized the way we approach security. Why?
 - All designs of systems we will study are public knowledge
 - Promotes scrutiny
 - Real-world security built on top of open standards
- Corollary: security can only be derived from a parameter that is explicitly secret — a secret **key** or **password**

Cryptography

Services and Protocols

- Usually, one is interested in a combination of security properties (e.g. a secure channel between two parties aims to guarantee confidentiality, authenticity and integrity)
- On the other hand, some of these properties do not directly follow from a single cryptographic technique, but rather from a combination of techniques
- Leading to what is known as **cryptographic protocols** (specifications for message exchanges that rely on cryptography to achieve a desired end)
- The security of those protocols relies not only on the security of the underlying cryptographic techniques, but also on subtle interactions between them

Cryptography

Real-world security

*The security of a system using cryptography **is not just** the security of the underlying cryptographic techniques*

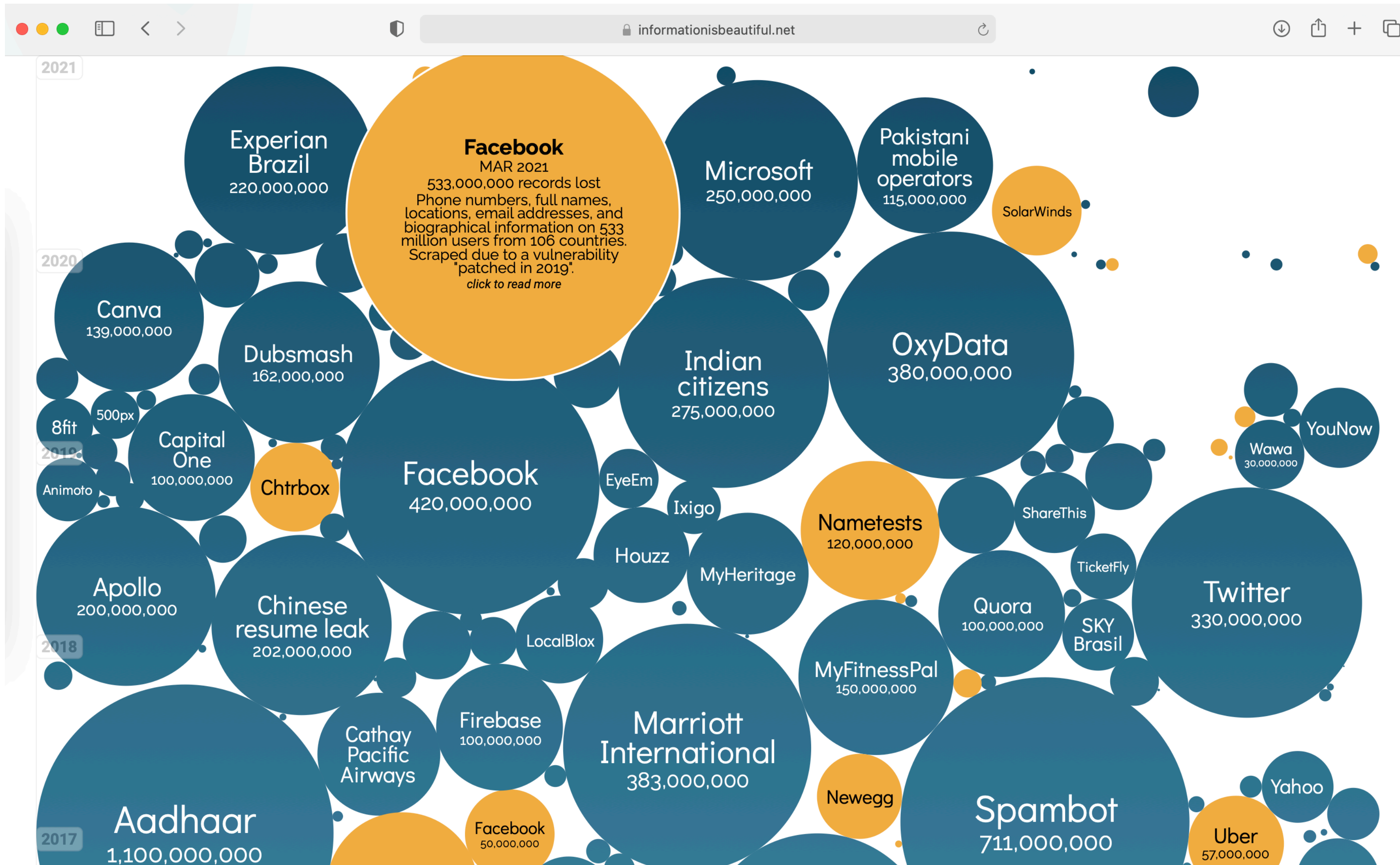
- We can distinguish (at least) the following levels when establishing the security of a system that uses cryptography
 - scheme
 - protocol
 - implementation (code)
 - usage
- **A breach at any of these levels jeopardises the security of the entire system!**

Real-world security

Never use your own crypto

- It is very easy to make mistakes
- It is very hard to find mistakes
- A plethora of bad examples
 - Cryptography can be **poorly designed**
 - E.g. 2G GSM mobile standard
 - Cryptography may **not match the application**
 - E.g. many TLS vulnerabilities
 - Cryptography can be **poorly implemented**
 - E.g. in software (Heartbleed) or even in hardware (Meltdown)

Data Breaches



```
[';--have i been pwned?']
```

<https://haveibeenpwned.com/>

Real-world security

 in 09/2022

CIBERSEGURANÇA

Vulnerabilidade em plataforma da DGS expôs dados detalhados dos portugueses

Uma vulnerabilidade na plataforma do Sinave permitia extrair informação sobre o NIF, morada, número de telefone, nome e data de nascimento dos cidadãos portugueses sem qualquer tipo de autenticação. Faltam auditorias digitais no Governo, dizem especialistas.

Karla Pequenino

5 de Setembro de 2022, 6:01



O Sinave é a plataforma onde se registam os dados sobre os portugueses infectados com covid-19 RUI GAUDÊNCIO

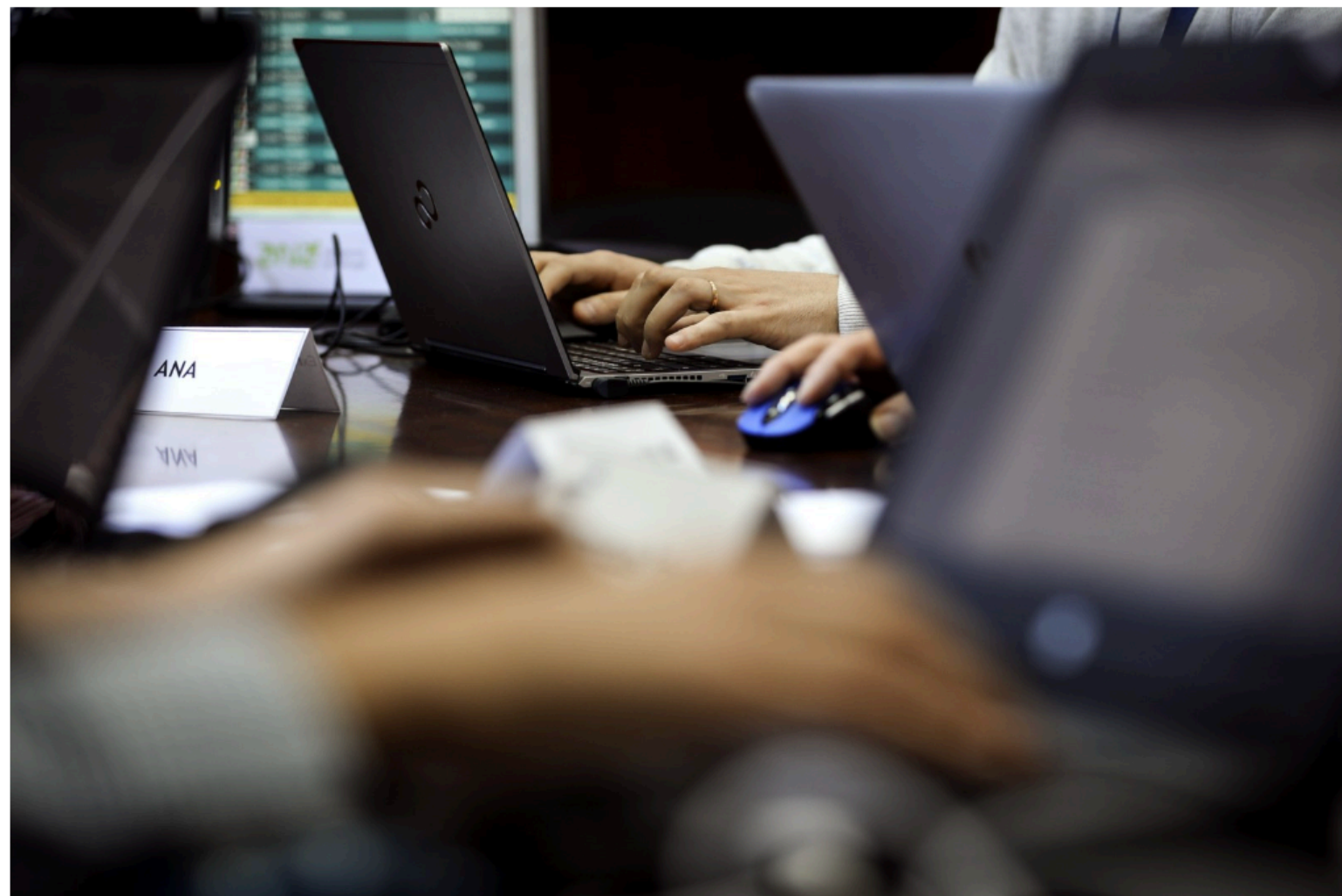
CIBERCRIME

Hackers atacam Estado-Maior-General das Forças Armadas e colocam documentos da NATO à venda na internet

O primeiro-ministro, António Costa, alegadamente só soube do caso porque foi informado pelos serviços secretos dos Estados Unidos.

PÚBLICO

8 de Setembro de 2022, 10:11



A NATO já exigiu explicações ao Governo português e, na próxima semana, o secretário de Estado da Digitalização e da Modernização Administrativa e o director do gabinete de segurança nacional vão a Bruxelas para uma reunião na sede da NATO. DANIEL ROCHA

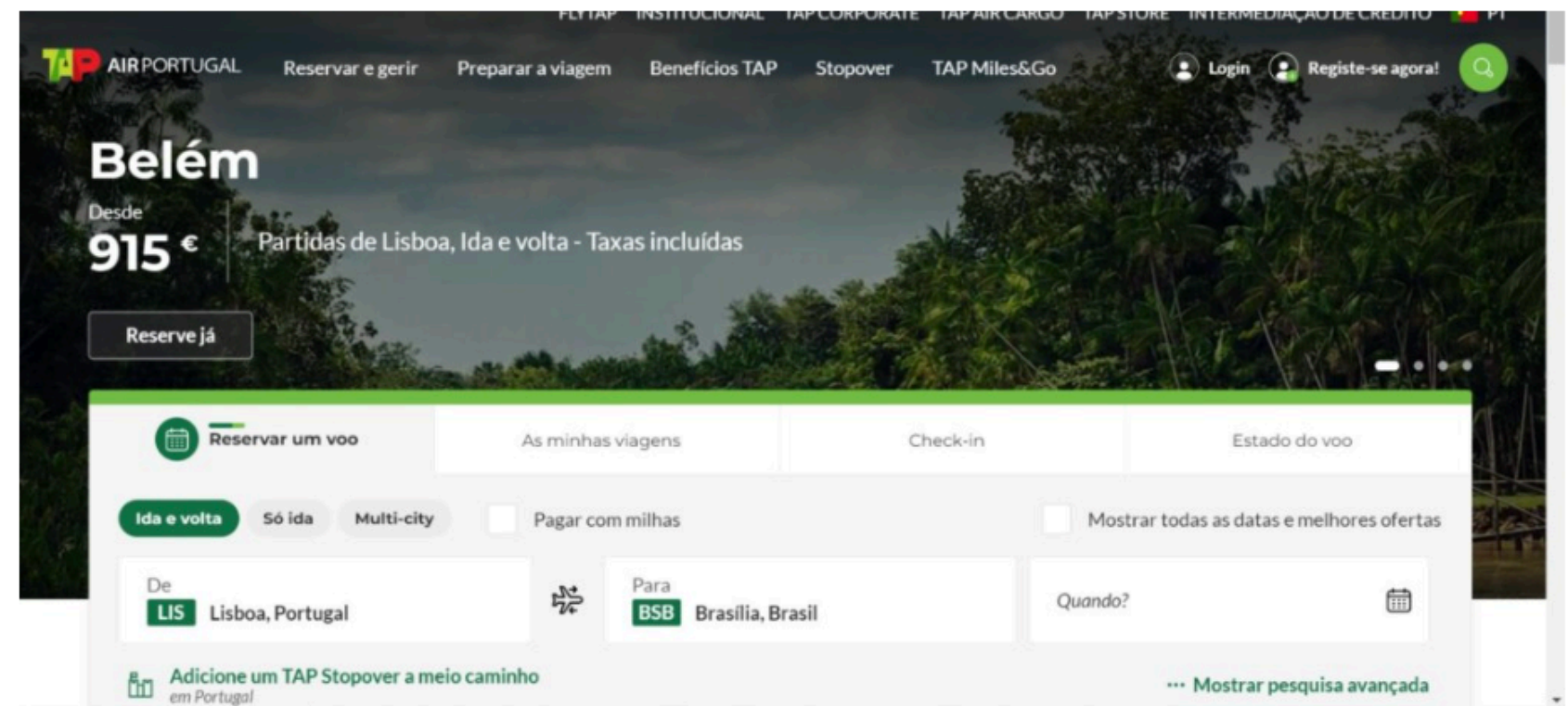
PIRATARIA INFORMÁTICA

Hackers publicam dados de clientes da TAP. Moradas, nomes e telefones entre informação divulgada

Funcionários governamentais podem estar entre os afectados. *Hackers* ameaçam publicar informações de 1,5 milhões de clientes. Empresa diz que dados de pagamento não foram exfiltrados da base de dados.

Miguel Dantas e Rui Barros

13 de Setembro de 2022, 12:39



Dados foram publicados esta segunda-feira

Real-world security

Modern cars are not secure

*Privacy Not Included

moz://a

- 📍 It's Official: Cars Are the Worst
- 🐦 Product Category We Have Ever
- ✉ Reviewed for Privacy



By Jen Caltrider, Misha Rykov and Zoë MacDonald | Sept. 6, 2023

Ah, the wind in your hair, the open road ahead, and not a care in the world... except all the trackers, cameras, microphones, and sensors capturing your every move. *Ugh*. Modern cars are a **privacy nightmare**.

All 25 car brands we researched earned our ***Privacy Not Included** warning label -- making cars the official worst category of products for privacy that we have ever reviewed.

<https://foundation.mozilla.org/en/privacynotincluded/articles/its-official-cars-are-the-worst-product-category-we-have-ever-reviewed-for-privacy/>

<https://www.securityweek.com/18k-nissan-customers-affected-data-breach-third-party-software-developer/>

DATA BREACHES

25k Nissan Customers Affected by Data Breach at Third-Party Software Developer

Nissan North America told roughly 25,000 customers that their personal information was exposed in a data breach via a third-party provider.



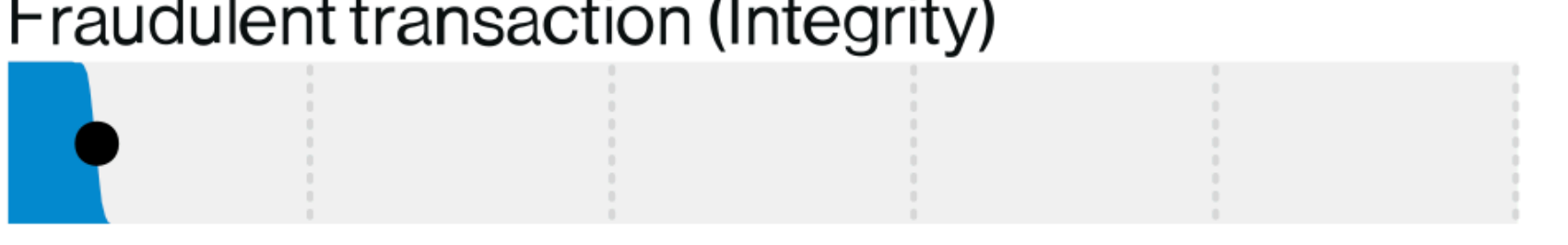
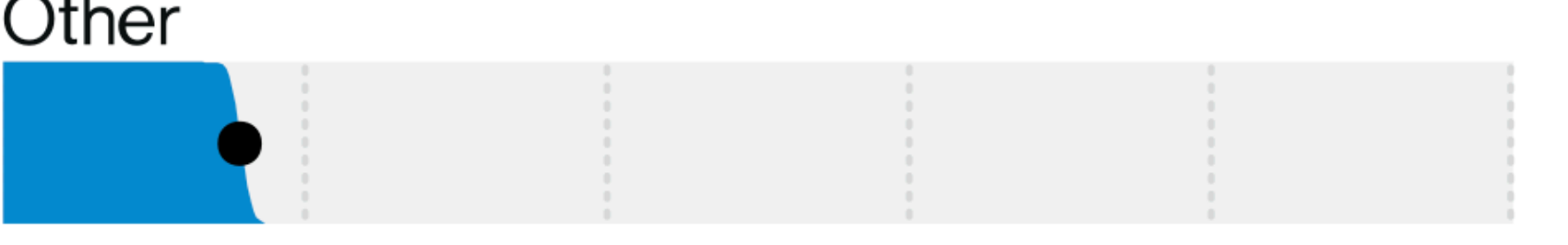
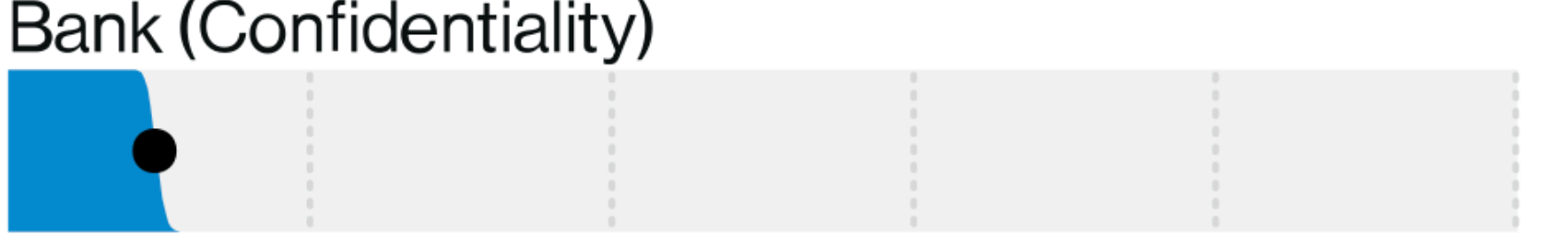
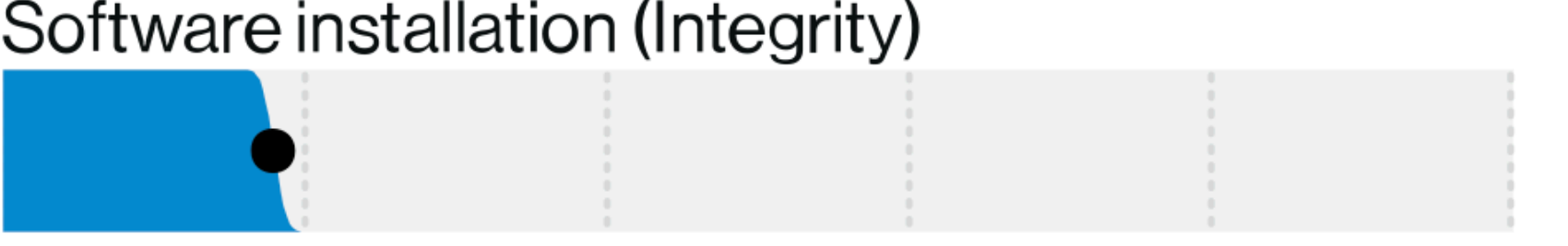
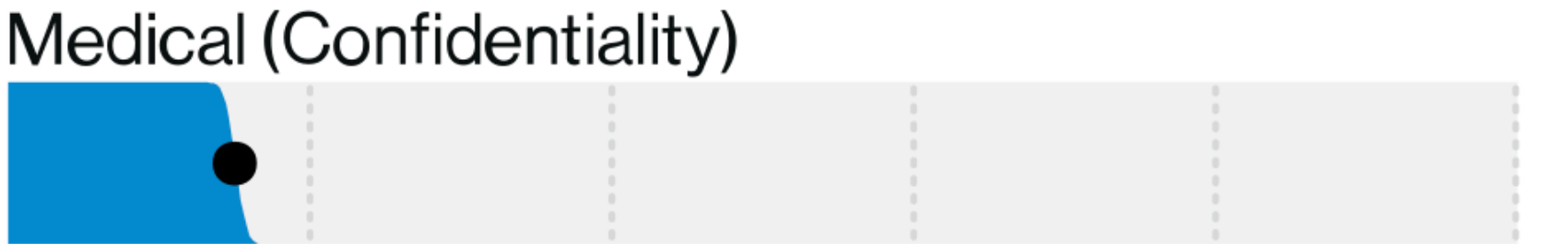
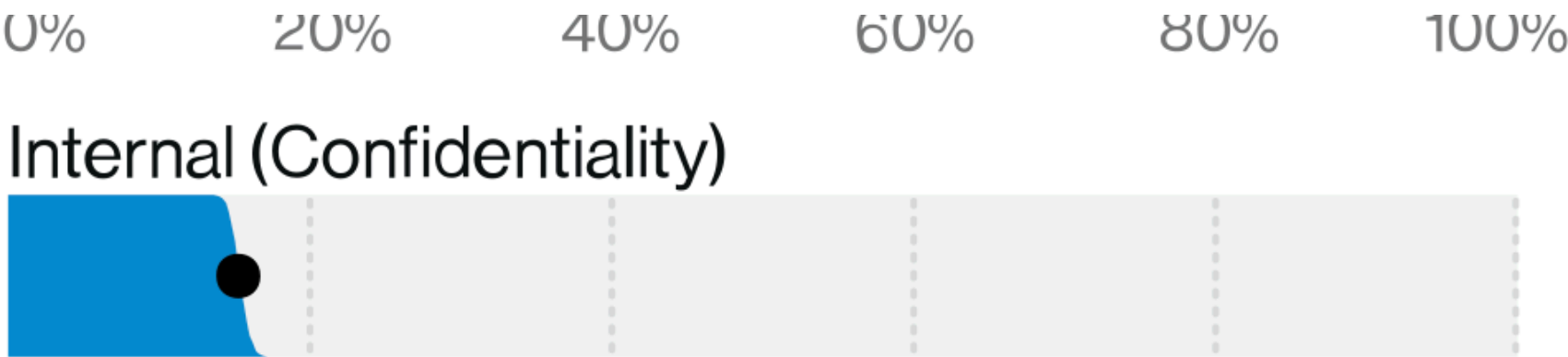
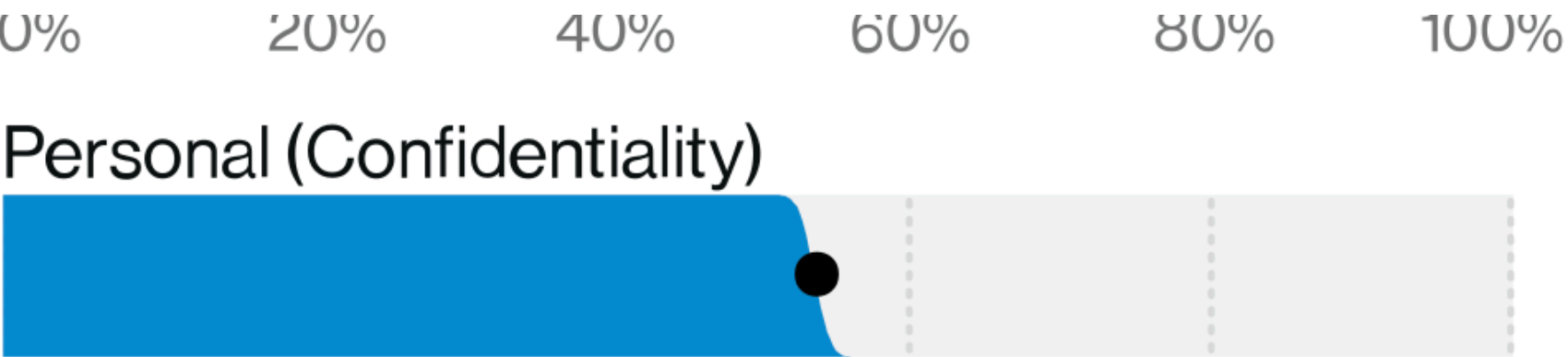
By [Ionut Arghire](#)
January 18, 2023



Nissan North America is informing roughly 25,000 customers that their personal information was exposed in a data breach at a third-party services provider.

Real-world security

Consequences (user perception)



Real-world security

It is actually getting worse?

RESEARCH-ARTICLE



Do Users Write More Insecure Code with AI Assistants?

Authors: [Neil Perry](#), [Megha Srivastava](#), [Deepak Kumar](#), [Dan Boneh](#) | [Authors Info & Claims](#)

CCS '23: Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security • Pages 2785 - 2799
<https://doi.org/10.1145/3576915.3623157>

Published: 21 November 2023 [Publication History](#)



28 1,600



Abstract

AI code assistants have emerged as powerful tools that can aid in the software development life-cycle and can improve developer productivity. Unfortunately, such assistants have also been found to produce insecure code in lab environments, raising significant concerns about their usage in practice. In this paper, we conduct a user study to examine how users interact with AI code assistants to solve a variety of security related tasks. Overall, we find that participants who had access to an AI assistant **wrote significantly less secure code** than those without access to an assistant. Participants with access to an AI assistant **were also more likely to believe they wrote secure code**, suggesting that such tools may lead users to be overconfident about security flaws in their code. To better inform the design of future AI-based code assistants, we release our user-study apparatus to researchers seeking to build on our work.

<https://doi.org/10.1145/3576915.3623157>

AI-Generated Code is Causing Outages and Security Issues in Businesses

Published September 13, 2024

Written by
 Fiona Jackson

Tariq Shaukat, CEO of Sonar, is “hearing more and more” about companies that have used AI to write their code experiencing downtime.

Businesses using artificial intelligence to generate code are experiencing downtime and security issues. The team at Sonar, a provider of code quality and security products, has heard first-hand stories of consistent outages at even major financial institutions where the developers responsible for the code blame the AI.

Could ‘insufficient reviews’ be a factor?

In late 2023, more than half of organisations said they encountered security issues with poor AI-generated code “sometimes” or “frequently,” as per a [survey](#) by Snyk. But the issue could worsen, as **90% of enterprise software engineers will use AI code assistants by 2028**, according to [Gartner](#).

Tariq Shaukat, CEO of Sonar and a former president at Bumble and Google Cloud, is “hearing more and more about it” already. He told TechRepublic in an interview, “Companies are deploying AI-code generation tools more frequently, and the **generated code is being put into production**, causing outages and/or security issues.”

“In general, this is due to insufficient reviews, either because the company has not implemented robust code quality and code-review practices, or because developers are scrutinising AI-written code less than they would scrutinise their own code.”

<https://www.techrepublic.com/article/ai-generated-code-outages/>

Real-world security

Always be skeptical

- Beware of
 - reckless use of AI for security-critical systems
 - ready-to-market / application-first over security
 - tech jargon
 - yourself (question your own assumptions)
 - many many other things



<https://www.usenix.org/conference/usenixsecurity18/presentation/mickens>